TOT-ally Forged: A Zero-Query Raw-Vector Forgery against TOT

Martin Feussner
Selmer Center, University of Bergen
martin.feussner@uib.no

13 October 2026

AI disclosure and review status. This audit used the OpenAI model Daybreak Blue at the ultra reasoning level. OpenAI Codex performed AI-assisted source review, attack-history searching, scheme reconstruction, cryptanalysis, implementation, experiments, and technical writing. Separate specialist AI agents performed adversarial review and a fresh-context AI agent independently reproduced the result with a separately written implementation. These were AI review and AI reproduction, not human verification. The technical, practical, adversarial AI, independent-reproduction, final attack-history, and Publication Reviewer gates all passed before public release. No independent human verification was performed or required. OpenAI Codex generated and selected the title and intentionally chose "TOT-ally Forged" as wordplay on the scheme name TOT.

Abstract

We give a public-key-only, zero-signing-query existential forgery against the signature construction in Shen and Tang's *TOT, a Fast Multivariate Public Key Cryptosystem with Basic Secure Trapdoor*, IACR ePrint 2013/771. The published signature interface takes a raw vector $M \in \mathbb{F}_2^{128}$ and accepts a vector σ precisely when the public quadratic map satisfies $P(\sigma) = M$. An adversary chooses any nonzero σ, evaluates the public key, sets $M = P(\sigma)$, and outputs (M, σ). The ordinary verifier accepts by construction, while the zero-query transcript makes M fresh. Because M lies in the image of P, this is also an honestly signable raw vector rather than an out-of-domain artifact.

We reconstruct and execute the attack at the same-inventors recommended signature row $(q, n, d, t) = (2, 128, 6, 64)$, for which more than 2^{90} security is claimed. The primary run generates an unselected conforming key, serializes only its full 1,073,280-bit quadratic public map, and separates key generation, the public-only forger, and the ordinary verifier. The forgery is accepted and four negative controls reject. A separately written fresh-context implementation independently reproduces the result. The claim is confined to the literal raw-vector message space specified by the paper and same-inventors patent. We make no claim against a separately added document-hashing or preimage-resistant encoding layer, and no novelty claim for signature-first or no-message existential forgery as a general technique.

1 Introduction

TOT is a multivariate public-key construction built from an extended-field trapdoor and secret affine maps [1]. Its 2013 paper gives encryption and signature algorithms. For signatures, the public key is a system of n quadratic polynomials over $\mathbb{F}_q$, a message is an n-component vector, and verification evaluates the public system on the alleged signature and compares the result directly with that vector.

This interface permits the classical verification-first construction. A forger need not invert the public map: it may select a preimage first and use public evaluation to learn its image. With no prior signing query, the image is a fresh message in the scheme's stated domain. This is the familiar signature-first or no-message weakness of bare trapdoor-inversion signatures; the contribution here is its concrete application, source binding, and full-parameter reproduction for TOT.

The result has the following properties:

- it uses the ordinary equation printed for TOT verification;
- it affects the complete recommended signature row without weakening a parameter;

- it uses only the serialized public key and makes zero signing queries;
- its output message is fresh and lies in the public map's image; and
- it is a design-level failure of the specified raw-vector signature interface, rather than a parser, randomness, or implementation defect.

Technique attribution. The standard attack-goal hierarchy and adaptive chosen-message security definition allow an adversary to output any fresh message/signature pair, including a message selected as a function of the public key and the candidate signature [4, 3]. We make no novelty claim for this definition, for choosing a signature before its message, or for public-map evaluation. We claim only the concrete attack against TOT's specified signature relation.

2 Exact target and claim boundary

2.1 Pinned target

The target is Wuqiang Shen and Shaohua Tang's *TOT, a Fast Multivariate Public Key Cryptosystem with Basic Secure Trapdoor*, IACR ePrint 2013/771 [1]. The current official record has one publicly visible object, published and last updated on 25 November 2013. Its 17-page PDF has SHA-256 digest

`8ee1200e43b60123cf02f0261bee8e381b1229fde8c7722df086d95e6b7784bc.`

The extracted text has SHA-256 digest

`4e95403d8f73be474ae0d57ac730370649d4271b2c9dc5b84bd9bb75b4bb794b.`

The ePrint gives the signature family $q = 2$, $n = 128$, $d \geq 6$, $t \geq 64$ and reports more than 2^{90} work for the best attack considered there. The same inventors' signature patent instantiates the boundary row exactly as

$$(q, n, d, t) = (2, 128, 6, 64),$$

again with a 2^{90} security claim [2]. That complete row is the experimental target. The attack itself depends only on the public map and therefore applies independently of the hidden root and affine-map choices.

2.2 Raw-vector message interface

Section 3.3 of the ePrint calls $M = (y'_1, \ldots, y'_n)$ the message to be signed, passes that vector directly to the trapdoor inversion, and defines verification only by comparison with the public-map output. It specifies no document hash, byte encoding, salt, domain separator, preimage check, or retry wrapper. The same-inventors patent independently describes storing the received message, transmitting the message/signature pair, evaluating the public map, and comparing the result with the stored message [2]. Its worked four-bit example passes the vectors directly.

Our claim is therefore about the stated raw message space $\mathbb{F}_2^{128}$. It does not assert that the adversary can target an independently chosen external document or invert a hypothetical document-to-vector hash. Adding such a transform would define an additional construction that is absent from the audited target and would need separate analysis.

No author implementation or normative byte-level public-key, message, or signature format was located. The experiment encoding transports the exact finite-field vectors and complete quadratic map between isolated processes; it is not claimed as an upstream wire format.

2.3 Dated attack-history result

No prior public attack specifically against Shen and Tang's TOT (IACR ePrint 2013/771, sole publicly exposed revision dated 25 November 2013) was located in searches performed through 13 October 2026. The search covered the exact title, ePrint identifier, authors, scheme name, patent family, citations, repositories, and combinations with attack, cryptanalysis, forgery, and break terminology. This is a bounded, dated search result rather than an absolute priority claim. Related attacks on multivariate and HFE-family systems do not disclose this exact-target raw-vector forgery.

3 The TOT signature relation

Let $E = \mathbb{F}_{q^n}$ and let $\phi : E \to \mathbb{F}_q^n$ be the coordinate isomorphism for a fixed basis. Key generation chooses distinct $h_1, \ldots, h_d \in E$ and sets

$$g(X) = \prod_{i=1}^{d} (X - h_i), \qquad G(X) = g(X)^t,$$

where $\gcd(t, q^n - 1) = 1$. It also chooses secret invertible affine maps $S, T : \mathbb{F}_q^n \to \mathbb{F}_q^n$. The public map is

$$P = T \circ \phi \circ G \circ \phi^{-1} \circ S.$$

The public key contains the coordinate polynomials of P; the trapdoor contains the roots and affine maps.

Let $v = t^{-1} \bmod (q^n - 1)$. To sign a raw vector M, the signer computes

$$Y = \phi^{-1}(T^{-1}(M)), \qquad Y_0 = Y^v,$$

finds a root X of $g(X) - Y_0$, and returns $\sigma = S^{-1}(\phi(X))$. The verifier accepts exactly when

$$\mathsf{Verify}(P, M, \sigma) = 1 \quad \Longleftrightarrow \quad P(\sigma) = M. \tag{1}$$

For the experimental row, $t = 64 = 2^6$ and $v = 2^{122}$ because $64 \cdot 2^{122} = 2^{128} \equiv 1 \pmod{2^{128} - 1}$. In characteristic two,

$$g(X)^{64} = \sum_{i=0}^{6} a_i^{64} X^{64i}.$$

The 64th-power Frobenius is $\mathbb{F}_2$-linear, and the exponents $0, \ldots, 6$ have binary weight at most two. Consequently the central map, and hence P, has Boolean algebraic degree at most two. Its full constant, linear, and quadratic coordinate representation occupies

$$128 \left(1 + 128 + \frac{128 \cdot 129}{2}\right) = 1{,}073{,}280$$

coefficient bits, matching the advertised public-key count.

4 Zero-query forgery

Theorem 1. *For every TOT public key $P : \mathbb{F}_2^{128} \to \mathbb{F}_2^{128}$ and every $\sigma \in \mathbb{F}_2^{128}$, the pair $(P(\sigma), \sigma)$ is accepted by the ordinary verifier. If the adversary makes no signing query, this pair is a fresh-message existential forgery against the specified raw-vector interface.*

Proof. The adversary evaluates the public key and defines $M = P(\sigma)$. Substituting the pair into Equation (1) gives $P(\sigma) = M$ identically, so verification accepts. Since there were no signing queries, M was not previously submitted to the signing oracle and is fresh. For signability, let $u = \phi^{-1}(S(\sigma))$. After applying T^{-1} and exponent v, the signer obtains $G(u)^v = g(u)^{tv} = g(u)$, so u belongs to the signer's root set and maps back to σ. Thus M is an honestly signable raw vector, rather than a value outside the signer's image. □

The experiment fixes a nonzero σ before generating the fresh key and checks that the resulting M is nonzero. These choices are stronger than needed for the theorem. The success probability of the algebraic attack is one for every key and chosen signature; the nonzero-message check only keeps the retained transcript easy to inspect.

5 Full-parameter reproduction

5.1 Primary implementation

The standard-library Python implementation constructs $\mathbb{F}_{2^{128}}$ in a polynomial basis, samples six distinct roots and two invertible affine maps, and realizes the exact central and public maps. It interpolates the

complete quadratic public key into 8,385 coefficient blocks of 128 bits. Before the attack, it checks affine inverses, the Frobenius normalization, the signing equation, and 515 public-versus-secret map evaluations. It also directly replays the patent's four-bit worked verifier vector.

Key generation, the public-only attacker, and verification execute as separate processes. The generator serializes the public map but no root, affine map, inverse, random seed, or honest signature. The attacker receives only that public map and a sealed empty signing-query transcript. It chooses the fixed nonzero σ, computes $M = P(\sigma)$, and writes the pair. A separate ordinary verifier applies Equation (1).

The coordinator's retained full-row run passed on its first unselected key. The complete run took 7.93 seconds, used 19,456 KiB peak resident memory and one worker, and the public evaluation including key parsing took 5.360155 milliseconds. The ordinary verifier accepted the forged pair. Four controls—changed message, changed signature, swapped fields, and a mutated public key—all rejected.

5.2 Independent reproduction

A fresh-context AI agent wrote a separate implementation from the public specification without inspecting or reusing the primary implementation. It generated a new conforming full-row key, gave its forger only public inputs, used no signing query or secret value, invoked the ordinary verifier, and repeated independent negative controls. Its sole sealed full-row run accepted the forged raw-vector pair and rejected all four controls. It took 6.798212471 seconds in total, used 20,480 KiB peak resident memory, and used one worker. The separately measured public-only attack and ordinary verification stages each completed in 0.09 seconds. The public package contains both implementations and stable wrappers for their complete runs.

5.3 What the experiment establishes

The experiment is not a statistical estimate of a rare weakness. Public evaluation proves the forgery for every correctly encoded public map; the full-row executions check the target reconstruction, public/private process boundary, parameter handling, and verifier behavior. The fresh keys are not selected for favorable structure, and no retry is used.

6 Impact, limitations, and repair direction

Under the literal interface, TOT does not meet existential unforgeability: an adversary obtains a fresh accepted pair with one public-map evaluation and no oracle query. The attack does not recover the secret key and does not enable signatures on an independently prescribed raw vector. Neither fact is required for existential forgery.

The result does not extend by itself to a construction that first maps an external document through a preimage-resistant encoding into $\mathbb{F}_2^{128}$. Such a wrapper would require the adversary to find a document whose encoding equals the backward-constructed $P(\sigma)$. An explicit, domain-separated, preimage-resistant document-to-vector transform is therefore a natural direction for blocking this attack. It would be a modified scheme and would need its own correctness and unforgeability proof; we do not claim a complete repair analysis here.

7 Reproducibility

The public artifact contains two standard-library Python implementations, the expected normalized outputs, source pins, and build instructions. From the attack directory, run

```
python3 reproduce.py
python3 reproduce-all-rows.py
```

Each command creates a fresh exact-row key in a temporary directory, performs the public-only attack, invokes the ordinary verifier and controls, removes ephemeral artifacts, and emits stable JSON. The package requires one worker and no network access.

Acknowledgements

The computations were performed on the Norwegian Research and Education Cloud (NREC), using resources provided by the University of Bergen and the University of Oslo.

References

[1] W. Shen and S. Tang. TOT, a fast multivariate public key cryptosystem with basic secure trapdoor. IACR Cryptology ePrint Archive, Report 2013/771, 2013. https://eprint.iacr.org/2013/771.

[2] W. Shen and S. Tang. Multivariate public key signature/verification system and signature/verification method. US Patent 9,948,463 B2, 2018; application publication US 2016/0234021 A1. https://patents.google.com/patent/US9948463B2/en.

[3] S. Goldwasser, S. Micali, and R. L. Rivest. A digital signature scheme secure against adaptive chosen-message attacks. *SIAM Journal on Computing*, 17(2):281–308, 1988.

[4] A. J. Menezes, P. C. van Oorschot, and S. A. Vanstone. *Handbook of Applied Cryptography*, Section 11.2.4. CRC Press, 1996. https://cacr.uwaterloo.ca/hac/.